

Clase 061 — Introducción al criptoanálisis

Parte: 2 — **Criptografía aplicada** · Fuente: *Serious Cryptography* (Aumasson) y *Cryptography Engineering* (Ferguson/Schneier/Kohno) ⌚ Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Adquirir una visión panorámica del criptoanálisis: el arte y la ciencia de romper cifrados. El alumno conocerá los modelos de ataque (solo texto cifrado, texto plano conocido, texto plano/cifrado elegido), las técnicas clásicas (frecuencias) y modernas (criptoanálisis diferencial y lineal a nivel conceptual), la paradoja del cumpleaños aplicada a colisiones, y cómo se mide la seguridad en "bits". El objetivo no es romper AES, sino entender cómo piensan quienes diseñan y evalúan primitivas.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Clasificar** ataques según el modelo (COA, KPA, CPA, CCA).
2. **Aplicar** análisis de frecuencias y de correlación a cifrados débiles.
3. **Explicar** a alto nivel el criptoanálisis diferencial y lineal.
4. **Calcular** costes de ataque en bits y aplicar la paradoja del cumpleaños.
5. **Evaluar** por qué una primitiva se considera "rota" aunque no sea práctica.

Temas

#	Tema	Por qué importa
1	Modelos de ataque (COA/KPA/CPA/CCA)	Definen las capacidades del adversario
2	Análisis de frecuencias	Base del criptoanálisis clásico
3	Ataque de fuerza bruta y "bits de seguridad"	Medir la resistencia
4	Paradoja del cumpleaños	Colisiones y su coste
5	Criptoanálisis diferencial	Cómo se evalúan cifrados de bloque
6	Criptoanálisis lineal	Aproximaciones lineales
7	"Roto" académico vs práctico	Interpretar titulares

Definiciones y características

- **COA (ciphertext-only)**: el atacante solo ve texto cifrado. Modelo más débil para el atacante.
- **KPA (known-plaintext)**: conoce pares plano/cifrado. **CPA (chosen-plaintext)**: elige los planos a cifrar. **CCA (chosen-ciphertext)**: elige cifrados a descifrar (el más fuerte).
- **Bits de seguridad**: $\log_2$ del esfuerzo del mejor ataque conocido. 128 bits $\approx$ inviable con tecnología actual.

- **Paradoja del cumpleaños:** las colisiones aparecen alrededor de $2^{(n/2)}$ intentos, no 2^n ; por eso un hash de 256 bits da ~ 128 bits frente a colisiones.
- **Criptanálisis diferencial:** estudia cómo diferencias en la entrada se propagan a la salida para distinguir un cifrado de uno aleatorio.
- **Criptanálisis lineal:** busca aproximaciones lineales entre bits de entrada, salida y clave con sesgo explotable.
- **Ataque "roto":** cualquier método mejor que la fuerza bruta, aunque siga siendo impracticable; señala margen erosionado.

Herramientas y preparación

```
pip install numpy matplotlib
python3 --version
```

Trabajo puramente analítico y local sobre cifrados de juguete y datos propios.

Laboratorio guiado

1. **Análisis de frecuencias automatizado.** Reutiliza el rompedor de sustitución de la clase 046 y mide cuántos caracteres necesitas para recuperar el texto con fiabilidad; grafica la tasa de acierto frente a la longitud.
2. **Fuerza bruta acotada.** Ataca un cifrado con espacio de claves reducido (p. ej. una clave de 24 bits en un cifrado de juguete) y mide el tiempo; extrapola cuánto costaría 56, 128 y 256 bits para interiorizar la inviabilidad.
3. **Paradoja del cumpleaños empírica.** Genera hashes truncados a n bits y cuenta cuántos necesitas para una colisión; compara con la predicción $2^{(n/2)}$. Grafica los resultados para varios n .
4. **Distinguidor diferencial (juguete).** Sobre un cifrado de bloque didáctico de pocas rondas, mide cómo una diferencia fija en la entrada produce diferencias sesgadas en la salida, ilustrando el criptanálisis diferencial.
5. **Interpreta un titular.** Analiza un anuncio del tipo "roto un ataque contra AES reducido a 7 rondas" y explica por qué no afecta a AES completo en la práctica.

Ejercicios

1. Clasifica tres escenarios reales según COA/KPA/CPA/CCA.
2. Verifica empíricamente la paradoja del cumpleaños para $n=32$ bits.
3. Estima el coste en años de romper 128 bits por fuerza bruta con supuestos razonables.
4. Explica por qué DES (56 bits) es rompible hoy y AES-128 no.
5. Describe en tus palabras el criptanálisis diferencial.
6. Diferencia "roto académicamente" de "roto en la práctica" con un ejemplo.

Reto verificable

Demuestra experimentalmente la paradoja del cumpleaños: para varios tamaños de salida n , genera valores aleatorios hasta la primera colisión, repite muchas veces y compara la media con $2^{(n/2)}$. **Criterio**

de aceptación: tus mediciones se ajustan al orden de $2^{(n/2)}$ (dentro de un margen estadístico), y explicas su implicación para el tamaño de los hashes.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Suponer que "roto" = "inseguro para todo"	Distingue ataque teórico de práctico
Calcular colisiones con 2^n	Es $2^{(n/2)}$ por el cumpleaños
Confiar en un cifrado propio "porque no lo rompí"	La ausencia de tu ataque no prueba seguridad
Ignorar el modelo de ataque	La seguridad depende de las capacidades del adversario
Subestimar side-channels frente a ataques matemáticos	En la práctica, la implementación cae antes

Preguntas frecuentes

 **¿Puedo aprender a romper AES?** No de forma práctica; AES resiste todo el criptoanálisis conocido. El valor está en entender cómo se evalúa y por qué confiamos en él.

 **¿Qué significa "128 bits de seguridad"?** Que el mejor ataque conocido requiere del orden de 2^{128} operaciones, inviable con recursos actuales.

 **¿Debería preocuparme por el criptoanálisis diferencial en mi app?** No directamente; usa primitivas estándar bien analizadas. Preocúpate por la implementación y los side-channels.

Referencias

- Aumasson, *Serious Cryptography*, cap. 3 y 6.
- Ferguson, Schneier, Kohno, *Cryptography Engineering*, cap. 2–3.
- Biham & Shamir, "Differential Cryptanalysis of DES" (referencia histórica).
- Matsui, "Linear Cryptanalysis Method for DES Cipher".

Siguiente clase

Clase 062 - Criptografía post-cuántica